



5

6

720 sp

نظري

كلية الهندسة المعلوماتية

السنة الثالثة

Web Services & Authentication Authorization

Programming
Languages



د. روان قرعوني

محتوى مجاني غير مخصص للبيع التجاري

RB Informatcs;

15/12/2024

لغات البرمجة

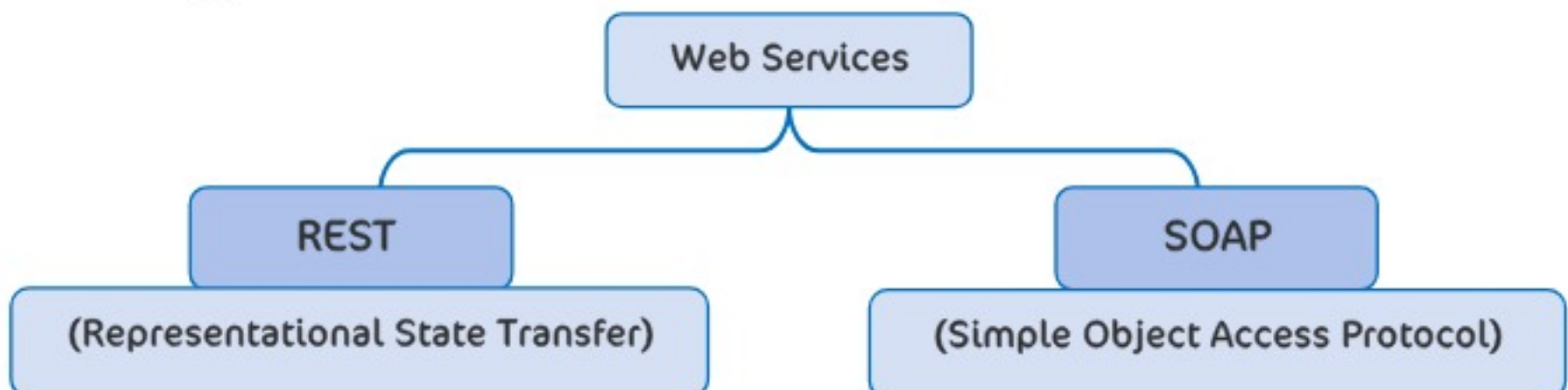
مرحباً بكم جميعاً اليوم سنغوص معاً في عالم خدمات الويب Web Services حيث تتقاطع التكنولوجيا مع الأمان. سنستعرض مفهوم الـ Authentication (التحقق من الهوية) ومفهوم الـ Authorization (التفويض)

Web Services

هي نوع من تطبيقات الويب التي تتيح تبادل الخدمات الإلكترونية بين التطبيقات أو الأنظمة المختلفة حيث يمكن للتطبيق الاتصال وطلب الخدمة عبر الانترنت باستخدام واجهته البرمجية بغض النظر عن لغة البرمجة أو الـ framework المستخدم.

✍ خلاصة:

- أي كتابة كود يقوم بمهمة محددة ثم ننشره على الإنترنت ليستخدمه الجميع بغض النظر إن كانت هذه الخدمات مدفوعة أو مجانية، على سبيل المثال: خدمة ضغط الملفات أو خدمة ترجمة النصوص google translate أي أنها تتيح لك ترجمة جملة معينة أو نص ما حيث تعود إليك مترجمة بأي لغة ترغب بها
- من مزايا الـ Web Services أن الكود الخاص بك يمكنه استخدام خدمات جاهزة دون الحاجة إلى كتابة كود جديد من الصفر، على سبيل المثال: إذا طلب العميل أن تتم ترجمة تطبيقه أو موقعه لجميع اللغات فلن اضطر لكتابة الكود الخاص لكل لغة بل يمكنني ببساطة استخدام google translate API (خدمة الترجمة) ومن خلالها يمكن ترجمة نصوص التطبيق لأي لغة مطلوبة، مع ملاحظة إمكانية وجود أخطاء بالترجمة نتيجة الترجمة الحرفية التي تقدمها هذه الخدمة، وهنا يجب إعادة النظر على النص بشكل سريع وتصحيح الأخطاء المحتملة.



REST Services

1. تتعامل مع ال object (resources) إذ توفر لنا الوصول لها والتعديل عليها

على سبيل المثال:

ال API المستخدمة في العملي، إذ يمكننا:

- إضافة موظف إلى المطعم باستخدام post employ service (أي ال employ يمثل ال resources)
- القيام بتعديل عليه put
- حذفه delete
- جلب المعلومات get

أي أنه في ال REST service كل خدمة لها API خاص لا يمكن تخصيص API لمجموعة خدمات.

2. ال REST هي أكثر استخداماً

وهو النوع الذي تم استخدامه في التدريب العملي عن طريق ال Postman
أي ال service التي نطلبها "Request" وتعيد لنا "Response" (JSON, XML, ...) هي نوع من ال REST services

SOAP Service

1. يتم التعامل مع service على أنها logic كامل أي مجموعة خدمات ضمن service واحدة

على سبيل المثال:

في البنك يقوم بتزويدك ب SOAP Service حيث تتضمن مجموعة من الخدمات مثل:

- الإيداع
 - السحب
 - التحويل
- ك service واحدة

2. لغة توصيفها هي WSDL (Web Service Description Language):

عبارة عن ملف بصيغة ال XML يقوم بوصف الخدمات ل SOAP Service معينة

3. SOAP UI

هي Tool مثل ال Postman نستخدمها لتجربة ال WSDL نقوم فيها باستيراد ال WSDL فتتولد ال Requests وال Response وال service التي بإمكاننا استخدامها، أي تستخدم هذه الأداة لاختبار خدمات الويب وتتيح للمستخدمين إنشاء اختبارات تلقائية وإجراء اختبارات الأداء والتحقق من استجابة الخدمات وتحليل البيانات.

4. تتوصف الرسالة بين العميل والخدمة في ال SOAP بصيغة XML وتتكون هذه الرسالة من عدة أجزاء رئيسية:

```

<soap-env: envelope>
  <soap-env: header>
    <!-- يحتوي على معلومات عن الرسالة --!>
  </soap-env: header>
  <soap-env: body>
    <!-- يحتوي على نص الرسالة --!>
  </soap-env: body>
  <soap-env: Fault>
    <!-- يحتوي على رسالة الخطأ --!>
  </soap-env: Fault>
</soap-env: envelope>

```



مقارنة:

SOAP	REST	
- تحتوي built-in security أي أن الحماية الخاصة بال services موصّفة بداخلها. - تعمل على أي بروتوكول. - تتضمن بال WSDL. - أكثر حماية (built-in Security)	- سهولة البرمجة. - تدعم كل أنواع الصيغ (نص، XML، JSON، plain text) وليس لها معيار توصيف محدد. - تستهلك band width عرض حزمة أقل.	إيجابيات
- تتوصف فقط بصيغة xml. - صعبة برمجياً. - تستهلك عرض حزمة أكبر لوجود خدمات وتفاصيل كثيرة "كتلة خدمات".	- تدعم فقط بروتوكولين HTTP و HTTPS - لا تحتوي built-in security حيث يجب تأمينها بطبقة أخرى تقوم بعملية authentication - أقل حماية.	سلبيات

- SOAP صعبة برمجياً لأن كود ال WSDL صعب وطويل وبالتالي التعديل عليه يكون صعباً.
- عرض الحزمة "band width" بال SOAP أكبر لأن ال Request وال Response أكثر من ال REST إضافة لتخزين تفاصيل أكثر.

بطلب من الدكتور: البحث عن SOAP UI و WSDL file.



كلّ هذا الكفاح سيكون جزءاً من قصّتك، لا معاناتك

Authentication & Authorization

Authentication (Who are you?)

- وتعني توثيق هوية المستخدم (أي من هو الذي يحاول تسجيل الدخول) وذلك لتتمكن من الوصول إلى بياناته.
- تحدد من قبل المستخدم وله صلاحية بتعديلها فهو من يحدد الـ Password ويستطيع تعديلها فيما بعد.

Authorization (What you can do?)

- وتعني المعلومات التي تحدد ما الذي يمكن للمستخدم القيام به من عمليات. يتم في هذه المرحلة إعطاء المستخدم صلاحيات الوصول إلى معلومات معينة.
- لا يمكن للمستخدم تحديد أو التعديل عليها

- تعتبر عملية التحقق من الهوية "Authentication" وسيلة لتأكيد البيانات الشخصية للمستخدم وتحديد هويته بينما تشير عملية "Authorization" إلى منح صلاحيات محددة لمستخدم معين، مما يتيح له الوصول إلى ميزات أو موارد معينة لا توفر لمستخدمين آخرين.
- الـ "Authentication" هو عملية التحقق من هوية المستخدم أي عند تسجيل الدخول إما يتحقق الأمر أو تظهر رسالة تفيد بعدم صحة المعلومات. بينما الـ "Authorization" أن المستخدم الذي ليس لديه صلاحية معينة لن يستطيع الوصول إليها.
- أولاً، تتم عملية "Authentication" أي يتم التحقق من البيانات ومن بعدها تتم عملية "Authorization".

⚡ خلاصة ما سبق:

Authentication	Authorization
إثبات هوية	إعطاء صلاحيات
مرئية للمستخدم	مخفية عن المستخدم
لها الأولوية قبل Authorization	تأتي بعد Authentication



طرق ال Authentication:

يتم التحقق من المستخدم عن طريق إحدى الطرق التالية:

1. شيء تعرفه something you know:

- مثل ال password أو عن الإجابة عن سؤال كـ "موقع السكن، اسم صديقك المفضل..." فكما يتم تعيين كلمة السر عند إنشاء الحساب يمكن تخصيص أسئلة وأجوبة بدلاً من كلمة السر.

2. شيء تملكه something you have:

- مثل بطاقة "ID" أو QR code ضمن تطبيق موبايل.

3. عن طريق المستخدم بحد ذاته Biometric:

- كبصمة اليد أو العين أو صورة الوجه.

أنواع ال Authentication:

يتم السماح للمستخدم بالوصول للمعلومات والخدمات عن طريق إحدى الطرق التالية:

1. Basic:

- نقوم بإدخال Username و Password عند استدعاء Service ومن سلبياتها أنها غير آمنة فهي قابلة للاختراق بسهولة لأنه مع كل service يتم إرسال الاسم وكلمة المرور عبر الشبكة والشبكة معرضة للاختراق.

2. Bearer:

- نقوم بإدخال ال Username وال Password لأول مرة ونقوم بإرجاع Token ويتم استخدام هذا ال Token في كل الطلبات اللاحقة.
- له صلاحية معينة. وتعتبر هذه الطريقة أيضاً غير آمنة لأن ال Token يتم إرساله عبر الشبكة أيضاً.

3. API Key:

- مع كل Request يتم توليد String مشابه لل Token بناءً على ال IP أو ال Mac Address الخاص بالجهاز، سلبياتها أنه لا يمكن الدخول إلا عن الطريق الجهاز نفسه فقط. ولهذا يعتبر هذا استخدامه قليل.

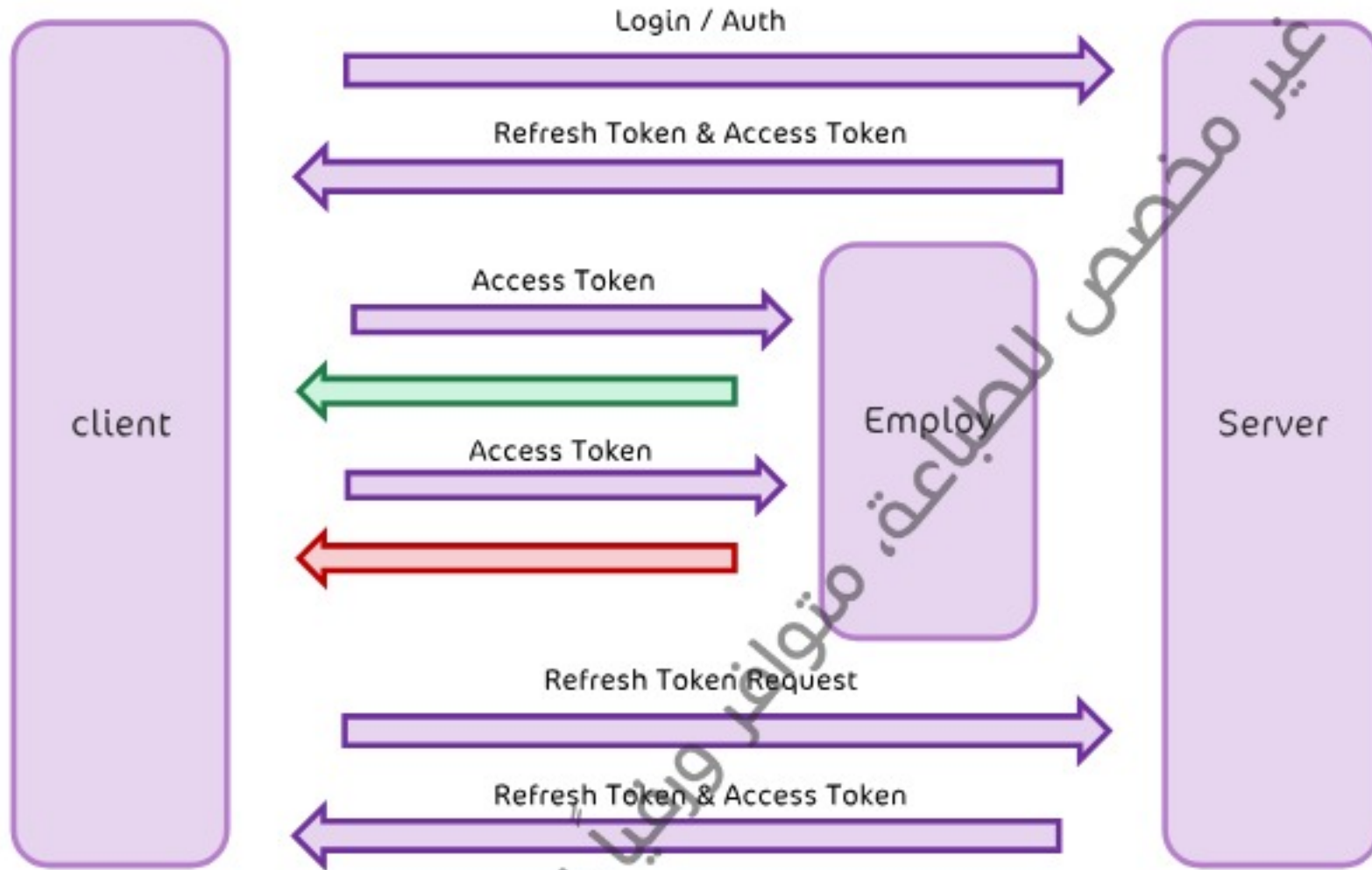
4. OAuth 2.0:

وهي الأكثر استخداماً، تعتمد المبدأ الآتي:

لنفرض أن لدينا Client يتواصل مع ال Server

- عند أول تسجيل دخول يتم عن طريق إدخال Username و Password حتى يعرف ال Client عن نفسه.
- نقوم بعملية Authentication ونعطي المستخدم ال Access Token و Refresh Token

- يقوم باستخدام الـ Access Token عند كل دخول، ومن خلال الـ Access Token أطلب الوصول للـ Resource ويتم الرد بـ "get employ" مثلاً، ولكن بعد عدد من الاستدعاءات تنتهي مدة صلاحية الـ Access Token عندها إذا أرسلنا الـ Access Token منتهية الصلاحية سيعيد لي Invalid Token
- عندها يقوم الـ Client باستعمال الـ Refresh Token المخزن لديه ويقوم بطلب Access Token جديد فيعيد له Access Token و Refresh Token جديدة.



مثال: تسجيل الدخول بواسطة Facebook كالألعاب التي يتم ربطها مع حساب Facebook حيث يتم تبادل المعلومات بين التطبيقين بدون تمرير كلمة المرور أو الحساب في العملية إذ يتم فقط تبادل الـ Token.

ملاحظة: مدة الـ Access Token أقصر من الـ Refresh Token.



The only way to do great work is to love what you are doing